

GENTLENESS

March 14, 2026

Access Control and Traceability System for Logistics: A Dual-Layer Approach

1 Introduction

It is widely recognized that some of the data collected, processed and stored in current information systems is of a personal nature, making it sensitive and requiring appropriate protection. Organizations, whether public or private, e.g., in domains like healthcare, finance, logistics that handle such data are consequently subject to increasingly stringent regulations. It is then crucial to equip information systems with mechanisms that control and restrict access to sensitive data to authorized users only. While experts in cybersecurity are involved in the design of advanced mechanisms to ensure data protection, an increasing number of individuals and organizations with limited technical expertise are tasked with managing large volumes of sensitive data. In most cases, these non-expert users are actually more aware of the operational realities of their domain and often have a more accurate and detailed vision of the field. However, the design and implementation of security policies in the actual information systems remain complex tasks that typically require significant expertise in formal security models. This complexity creates a gap between non-expert stakeholders, who are able to express their security requirements in natural language or through informal specifications, and the technical mechanisms needed to enforce these requirements effectively. As a result, there is a risk that the intended security objectives are either misinterpreted or only partially implemented, leading to vulnerabilities or inconsistencies.

Modern supply chains face critical challenges in:

- **Security:** Unauthorized access to facilities, systems, or data
- **Compliance:** Meeting regulatory requirements (GDPR, ISO 27001, customs regulations)
- **Traceability:** Tracking components through complex supply networks
- **Fraud Prevention:** Detecting counterfeit or diverted components

1.1 Motivation

Current solutions fall short because:

- Traditional AC systems lack **supply-chain context**
- Traceability systems don't integrate with **physical/digital access controls**
- No unified framework for **end-to-end component lifecycle management**

1.2 Project Objectives

Develop a **dual-layer access control system** that:

1. **General AC Layer:** Role-based access with attribute extensions for:
 - Multi-facility environments
 - Temporary access (contractors, auditors)
 - Emergency overrides with audit trails
2. **Logistics-Specific Layer:** Specialized for component traceability with:
 - Component-level access permissions
 - Automated compliance checking
 - Integration with IoT sensors (RFID, GPS)
 - Blockchain-backed provenance records

1.3 General Access Control Layer

Table 1: General AC Layer Components

Component	Functionality
Identity Management	Centralized user/device identity repository with MFA support
Policy Engine	ABAC (Attribute-Based Access Control) with temporal constraints
Access Gateway	API-based gateway for all access requests
Audit Module	Immutable logging of all access events with cryptographic hashing
Emergency System	Break-glass procedures with mandatory post-event review

1.4 Logistics-Specific Layer

Table 2: Logistics-Specific Components

Component	Functionality
Component Registry	Unique digital twins for all physical components
Provenance Engine	Blockchain-backed record of component custody chain
Compliance Checker	Automated verification against regulatory requirements
IoT Interface	Integration with RFID readers, GPS trackers, and environmental sensors
Traceability API	Query interface for component history and current status

2 Key Innovations

2.1 General AC Layer

- **Context-Aware Access:** Considers time, location, and operational status
- **Temporary Credentials:** QR-code based time-limited access for visitors
- **Behavioral Biometrics:** Continuous authentication via typing/navigation patterns
- **Policy-as-Code:** Version-controlled access rules in declarative language

2.2 Logistics-Specific Innovations

Table 3: Logistics-Specific Innovations

Innovation	Description
Component-Level AC	Granular permissions tied to individual components/batches
Dynamic Segregation	Automatic access restrictions based on component state (quarantined, released)
Predictive Compliance	ML-based forecasting of compliance risks
Physical-Digital Link	Cryptographic binding between physical components and digital records
Supply Chain Graph	Visualization of component flows and access points

3 Implementation Details

3.1 Technical Stack

Table 4: Technical Implementation

Component	Technology	Purpose
Identity Management	Keycloak + LDAP	Centralized authentication
Policy Engine	OpenPolicyAgent	Attribute-based decisions
Blockchain	Hyperledger Fabric	Immutable provenance records
IoT Integration	MQTT + Node-RED	Sensor data ingestion
Database	PostgreSQL + TimescaleDB	Temporal access data
API Gateway	Kong	Secure access to services
Frontend	React + D3.js	Visualization dashboard

3.2 Data Model

[language=JSON,caption=Component Access Record Schema] "component_{*i*}*d*" : "UUID", "current_{*i*}*location*" : "facility-1/zone-a/shelf-42", "access_{*r*}*ules*" : ["role" : "quality-inspector", "permissions" : ["read", "test"], "validity" : "event" : "received", "timestamp" : "2026-03-10T14:30:00Z", "actor" : "supplier-x", "location" : "dock-3", "signature"

4 Use Cases

4.1 General Access Control

- **Multi-Site Access:** Employee accesses facilities in different countries with localized permissions
- **Contractor Management:** Temporary access for maintenance crews with automated expiration
- **Emergency Access:** Firefighters gain one-time access during incident with mandatory review

4.2 Logistics-Specific Scenarios

Table 5: Logistics Use Cases

Scenario	System Response
Counterfeit Detection	Flags component with mismatched digital/physical fingerprint
Temperature Excursion	Automatically revokes access to sensitive components
Recall Management	Instantly identifies all affected components and their locations
Custody Transfer	Updates blockchain records and adjusts access permissions
Audit Trail Generation	Produces compliance reports with cryptographic proof

5 Evaluation Plan

5.1 Metrics

Table 6: Evaluation Metrics

Metric	Measurement Method
Access Decision Time	Latency between request and response
Policy Accuracy	False positive/negative rates in access decisions
Traceability Completeness	Percentage of component lifecycle captured
Fraud Detection Rate	Successful identification of simulated fraud attempts
System Usability	SUS score from user testing
Compliance Coverage	Percentage of regulatory requirements automated

5.2 Test Scenarios

- **General AC Tests:**
 - Role inheritance scenarios (e.g., manager inheriting team permissions)
 - Emergency access procedures with mandatory post-event review
 - Cross-facility permission propagation and revocation
 - Concurrent access attempts from multiple locations
 - Session timeout and reauthentication tests
- **Logistics-Specific Tests:**
 - Counterfeit component injection with digital/physical mismatch detection
 - Environmental violation simulation (temperature/humidity excursions)
 - Custody transfer with incomplete documentation attempts
 - Recall simulation with automated access revocation
 - Supply chain disruption scenarios (delayed shipments, rerouted components)
- **Integration Tests:**
 - IoT sensor data injection and access policy triggers
 - Blockchain synchronization under network latency
 - Third-party system interoperability (ERP, WMS)
 - Mobile device access in low-connectivity environments

5.3 Test Environment

Table 7: Test Infrastructure

Component	Configuration
Hardware	Dell R740 servers (2x), Raspberry Pi 4 (10x for IoT simulation)
Network	Segmented VLANs with firewall rules mimicking real facilities
Database	PostgreSQL 15 with TimescaleDB extension for temporal data
Blockchain	Hyperledger Fabric 2.4 network (4 peers, 1 ordering service)
IoT Simulators	MQTT brokers with temperature/humidity/GPS data generators
Load Testing	Locust.io for simulating 10,000 concurrent users

6 Implementation Roadmap

6.1 Phase 1: General AC Layer (Weeks 1-6)

1. Identity Management Setup

- Deploy Keycloak with LDAP integration
- Implement MFA (TOTP + hardware tokens)

- Create role hierarchy and attribute definitions

2. Policy Engine Development

- Define policy language schema
- Implement OpenPolicyAgent integration
- Create temporal and contextual rule templates

3. Access Gateway Implementation

- Develop REST API endpoints
- Implement rate limiting and request validation
- Create SDKs for common programming languages

4. Audit System

- Design immutable logging schema
- Implement cryptographic signing of logs
- Develop audit trail visualization

6.2 Phase 2: Logistics Layer (Weeks 7-12)

1. Component Registry

- Design digital twin schema
- Implement unique identifier generation
- Create bulk import/export tools

2. Provenance Engine

- Set up Hyperledger Fabric network
- Develop chaincode for custody transfers
- Implement privacy-preserving data sharing

3. Compliance Module

- Map regulatory requirements to system rules
- Implement automated compliance checking
- Develop report generation templates

4. IoT Integration

- Develop MQTT message handlers
- Implement sensor data validation
- Create alerting for environmental violations

6.3 Phase 3: Integration and Testing (Weeks 13-16)

1. System Integration

- Connect general AC and logistics layers
- Implement cross-layer policy synchronization
- Develop unified management interface

2. Performance Testing

- Conduct load tests with simulated users
- Measure decision latency under load
- Optimize database queries and caching

3. Security Testing

- Penetration testing by external team
- Fuzz testing of API endpoints
- Cryptographic validation of blockchain records

4. User Acceptance Testing

- Conduct workshops with logistics personnel
- Gather feedback on workflow integration
- Refine user interfaces based on input

7 Expected Challenges and Mitigations

Table 8: Anticipated Challenges and Solutions

Challenge	Potential Impact	Mitigation Strategy
Blockchain Performance	Slow transaction processing under load	Implement off-chain computation with periodic batching
IoT Data Variability	Inconsistent sensor data quality	Develop data validation and cleaning pipelines
Cross-Border Compliance	Conflicting international regulations	Modular policy templates with jurisdiction-specific overrides
User Resistance	Low adoption due to workflow changes	Comprehensive training and change management program
System Complexity	Difficult maintenance and debugging	Modular architecture with clear interfaces between components
Data Privacy	Risk of exposing sensitive supply chain data	Implement differential privacy for analytics and role-based data masking

8 Future Extensions

8.1 Enhanced Capabilities

- **AI-Powered Anomaly Detection**
 - Machine learning models for access pattern analysis
 - Predictive maintenance based on component usage patterns
 - Natural language processing for incident reports
- **Extended Ecosystem Integration**
 - Connections to major ERP systems (SAP, Oracle)
 - Integration with customs clearance systems
 - APIs for third-party logistics providers
- **Advanced Physical Security**
 - Biometric access control integration
 - Drone-based facility monitoring
 - Smart packaging with embedded sensors

8.2 Research Directions

- Formal verification of access control policies
- Quantum-resistant cryptography for long-term provenance records
- Decentralized identity solutions for supply chain participants
- Energy-efficient consensus mechanisms for blockchain
- Privacy-preserving analytics across competing organizations

9 Conclusion

This dual-layer access control system represents a **paradigm shift** in logistics security by:

- **Unifying physical and digital access control** in a single framework
- **Enabling end-to-end traceability** from component manufacture to final assembly
- **Automating compliance verification** across complex regulations
- **Providing real-time visibility** into supply chain security posture
- **Reducing fraud opportunities** through cryptographic binding of physical/digital identities

The system’s **modular architecture** allows for:

- Incremental deployment starting with either layer
- Customization for specific industry requirements
- Integration with existing enterprise systems
- Scalability from single facilities to global supply chains

Expected impacts include:

- reduction in access-related security incidents

- faster response to supply chain disruptions
- automation of compliance reporting
- improvement in counterfeit detection rates